

Министерство науки и высшего образования Российской Федерации
федеральное государственное автономное образовательное учреждение
высшего образования
«Московский физико-технический институт
(национальный исследовательский университет)»

ПРИКАЗ

от 29.11.2023

№ 4842-1

Об утверждении требований к проектированию и разработке ИС, модулей, сайтов, отдельных сервисов в части ИБ и защиты ПДн

В целях обеспечения безопасности персональных данных в информационных системах с обработкой персональных данных приказываю:

1. Утвердить требования к проектированию и разработке информационных систем, модулей, сайтов, отдельных сервисов с обработкой персональных данных (далее – ИСПДн) в части информационной безопасности и защиты персональных данных (Приложение 1).
2. Ответственность за соблюдение требований п. 1, 2 и 3 приложения 1 к настоящему приказу возложить на руководителя структурного подразделения – заказчика разработки системы.
3. Начальнику управления информационных технологий Пирогову Р.Ю. в течение 5 рабочих дней с момента подписания приказа обеспечить его размещение на странице mirt.ru/it в разделе «Документы» и проводить его своевременную актуализацию.
4. Заведующей канцелярией административного отдела Гусевой М.А. довести настоящий приказ до сведения руководителей структурных подразделений в течение 3 рабочих дней с даты подписания приказа.
5. Контроль исполнения структурными подразделениями требований п. 2 приказа возложить на курирующих проректоров, директоров соответствующих структурных подразделений.
6. Контроль исполнения настоящего приказа возложить на первого проректора Анохову Е.В.

Ректор

Д.В. Ливанов

Подлинник электронного документа, подписанный электронной подписью, хранится в СЭД МФТИ	
Сертификат:	1611C72F546E90E91FE65B1D699BB9E5
Владелец:	Анохова Елена Владимировна, ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ МОСКОВСКИЙ ФИЗИКО-ТЕХНИЧЕСКИЙ ИНСТИТУТ (НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ) , первый проректор
Действителен: с 18.04.2023 по 11.07.2024	

Требования к проектированию и разработке информационных систем, модулей, сайтов, отдельных сервисов в части информационной безопасности и защиты персональных данных

1. Проектирование и разработка информационных систем, модулей, сайтов, отдельных сервисов с обработкой персональных данных

1.1. Разработка информационных систем, модулей, сайтов, отдельных сервисов (далее – систем) с обработкой персональных данных (далее – ИСПДн) подразделениями МФТИ, Физтех в том числе с привлечением внешних подрядчиков, производится на основании соответствующего приказа по МФТИ, Физтех.

В приказе должны быть указаны:

- цели разработки;
- заказчик разработки;
- наименование подразделения-владельца системы;
- лица, ответственные за администрирование и обеспечение безопасности разрабатываемой системы.

1.2. В виде приложения к приказу на разработку системы должен быть оформлен проект системы, содержащий, в том числе:

- перечень субъектов персональных данных (далее – ПДн) и полный перечень ПДн, планируемых к обработке, для определения требуемого уровня защищенности;
- меры обеспечения безопасности ПДн соответствующие требуемому уровню защищенности, определяемые на основании приказа ФСТЭК России от 18.02.2013 г. №21 и частной модели угроз МФТИ;
- проект регламента управления правами и предоставления доступов к системе операторам ИСПДн.

1.3. Обязательно предварительное согласование проекта системы с управлением информационных систем (далее – УИТ) в части:

- размещения ИСПДн на серверах;
- подключения к сетям информационного обмена;
- настройки авторизации пользователей в ИСПДн с применением корпоративного аккаунта МФТИ;
- обеспечения безопасности ПДн;
- информационного обмена с системами МФТИ, администрируемыми УИТ.

1.4. В случае привлечения внешних подрядчиков к разработке ИСПДн для МФТИ, обязательно заключение договора на разработку системы и соглашения о неразглашении информации (NDA).

1.5. Передача данных, за исключением общедоступных, из ИСПДн МФТИ в системы, размещённые на ресурсах подрядчика, запрещается.

1.6. Ввод в эксплуатацию разработанных систем проводится после обязательного аудита со стороны УИТ в соответствии с приказом о внедрении и использовании информационных систем и сервисов №3212-1 от 28.10.2022 г.

2. Обязательные меры информационной безопасности

2.1. При проектировании ИСПДн МФТИ необходимо соблюдать требования федерального закона «О персональных данных» от 27.07.2006 № 152-ФЗ, базовых мер информационной безопасности согласно приказа ФСТЭК России от 18.02.2013 г. №21, а также адаптированных и уточнённых мер информационной безопасности МФТИ:

- Сервера с ИСПДн размещаются только во внутренней сети МФТИ, Физтех без выхода к Интернет.
- На начальном этапе настройки сервера и разрабатываемой системы разрешается непродолжительное подключение сервера на выход в Интернет. На этом этапе доступ к информационным системам МФТИ для обмена Пдн запрещается.
- Доступ из Интернет к серверам, на которых размещается ИСПДн, запрещён, за исключением случаев наличия веб-интерфейса к ИСПДн, предусмотренного проектом.

При разработке ИСПДн с веб-интерфейсом, доступ к которому необходим из Интернет, такой доступ разрешается только через прокси сервер МФТИ, при этом доступ из Интернет разрешается только для субъекта Пдн к своим персональным данным. Доступ для операторов, администраторов и разработчиков ИСПДн из Интернет запрещён.

2.2. Функционал ведения реестра операторов с доступом к Пдн. Интерфейс администратора ИСПДн должен иметь возможность формировать соответствующий отчет, а также механизм выгрузки из журнала регистрации в соответствии с Положением о порядке уничтожения персональных данных МФТИ. Отчет по операторам, имеющим доступ к Пдн системы должен содержать следующую информацию: ФИО оператора, должность, подразделение, IP адрес компьютера оператора, дата и время входа в систему.

3. Информация для обязательного размещения на веб-сайтах с обработкой персональных данных

3.1. В соответствии с требованиями Федерального закона от 27 июля 2006 г. N 152-ФЗ «О персональных данных» на веб-сайтах, обеспечивающих интерфейс к информационным системам с обработкой персональных данных должна быть размещена Политика оператора в отношении обработки персональных данных.

Поскольку Политика должна быть размещена на каждой странице, где осуществляется сбор

Пдн, то необходимо разместить ссылку на Политику в подвале сайта.

3.2. Если на сайте осуществляется сбор ПДн, то необходимо получать согласие субъекта ПДн на обработку ПДн соответствующее утвержденной форме в приложении к Положению о защите персональных данных МФТИ.

Если не осуществляется: сбор специальных и биометрических ПДн, сбор ПДн для включения в общедоступные источники ПДн, трансграничная передача ПДн, передача ПДн работников третьим лицам и принятие решений, порождающих юридические последствия в отношении субъекта ПДн, на основании исключительно автоматизированной обработки его ПДн, то письменное согласие не обязательно, достаточно разместить на сайте ссылку на текст согласия на обработку ПДн и получать подтверждение согласия электронным способом (например, установкой соответствующей отметки в контрольном поле).

3.3. При использовании файлов cookie, содержащих ПДн, необходимо размещать на сайте соответствующее уведомление (например, методом pop-up) и получать согласие на обработку файлов Cookie. При этом на сайте необходимо разместить ссылку на политику обработки Cookie, кратко определяющую цель их обработки, которую также необходимо разместить в подвале сайта.

3.4. На веб-сайтах запрещается использование иностранных метрических сервисов (например, Google Analytics). При использовании Российских метрических сервисов, (например, Яндекс Метрика) необходимо соблюдать требования конфиденциальности ПДн, определённые владельцем сервиса, в том числе запрет передавать в Метрику информацию, содержащую ПДн.

4. Контроль обеспечения безопасности персональных данных

4.1. На основании п.11.11 Положения о защите персональных данных МФТИ контроль за реализацией мер по технической защите ПДн в информационных системах, не входящих в информационно-технологическое пространство МФТИ, осуществляет УИТ.

4.2. Для выполнения УИТ контролирующих функций администраторы и разработчики, указанных информационных систем, предоставляют администратору информационной безопасности следующую информацию:

- рабочую документацию на информационную систему;
- временные учетные записи с административным доступом, необходимые для проведения контроля (для доступа к ИСПДн, для доступа к операционным системам серверов, на которых функционируют ИСПДн, для доступа к другим техническим средствам защиты информации, непосредственно обеспечивающим безопасность ПДн);
- исходный код и/или конфигурационные файлы информационных систем.

4.3. Контроль за реализацией мер защиты ПДн в информационных системах ПДн проводится непосредственно перед вводом в эксплуатацию информационной системы, далее не реже 1 раза в год с момента ввода системы в эксплуатацию.